University Research and Lab Asset Tracker

Phase 4

Nhóm BPT | Môn Cơ sở dữ liệu | Học kỳ 1 năm 2026 2027

6. Thiết kế tích hợp ứng dụng

Phase 4 tiếp nối cơ sở dữ liệu đã xây dựng ở Phase 3 để xác định đầy đủ giao diện, backend, cách kết nối và tiêu chí bảo vệ đồ án University Research & Lab Asset Tracker. Nhóm BPT sử dụng Node.js, Express và PostgreSQL 17 cho phương án triển khai. Sản phẩm của giai đoạn bàn giao này là thiết kế tích hợp có thể thực hiện trực tiếp; ứng dụng web, buổi trình diễn và đánh giá đồng đội chưa được thực hiện.

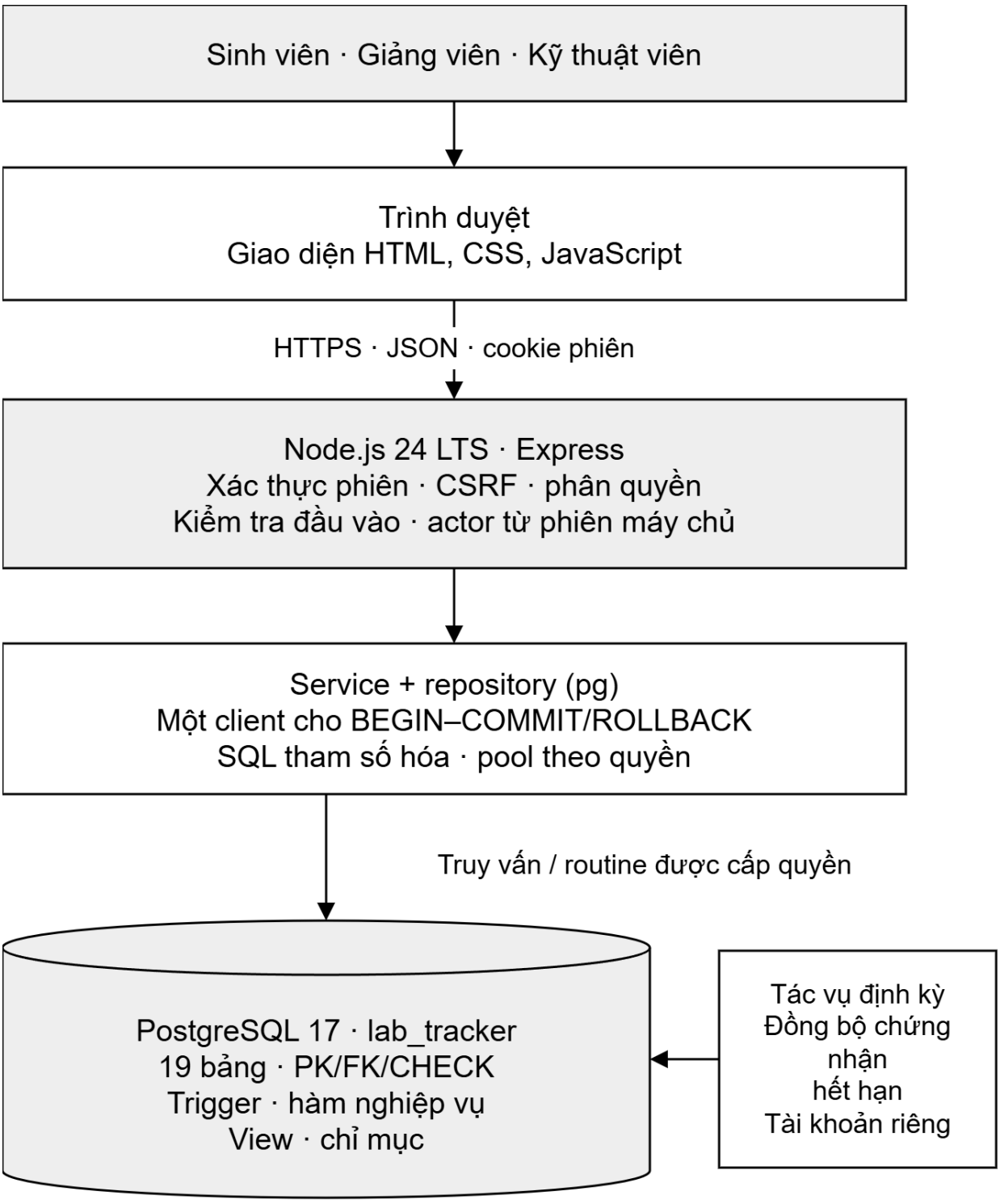
6.1. Mục tiêu và phạm vi

Các yêu cầu chức năng FR01–FR08 được khai báo tại Phase 1, mục 1.2; các yêu cầu phi chức năng NFR01–NFR05 và mục tiêu định lượng chỉ ghi tại Phase 1, mục 1.4. Phase 4 chuyển các yêu cầu đó thành màn hình, API, kiểm tra quyền và ca nghiệm thu. Ma trận tại mục 7.2 dùng đúng mã FR của Phase 1.

Tham chiếu Phase 1	Phương pháp xác nhận tích hợp	Bằng chứng cần thu
NFR01	Gây lỗi giữa nghiệp vụ qua API rồi đối chiếu các bảng liên quan; tái dùng kiểm thử SQL Phase 3.	HTTP response, request_id và SELECT trước/sau cho thấy rollback toàn bộ.
NFR02	Dùng quy mô và mục tiêu tại Phase 1 mục 1.4; đo riêng SQL, thời gian chờ pool, HTTP và trình duyệt theo mục 7.5.	Các mẫu thời gian, cấu hình môi trường, p95 và EXPLAIN gắn cùng lần chạy.
NFR03	Kiểm tra cookie/CSRF, phiên hết hạn, giả mạo danh tính và quyền đọc/ghi bằng AT12–AT13.	Request/response thực tế, cấu hình triển khai và log không chứa bí mật.
NFR04	Thực hiện sao lưu và phục hồi sang database mới theo mục 9.3; so sánh với mục tiêu Phase 1.	Log phục hồi, thời điểm bản sao, thời gian phục hồi và đối chiếu dữ liệu.
NFR05	Thử biên giờ truy cập, ngày hết hạn và cách hiển thị DATE trước/sau tác vụ thời gian.	Dữ liệu máy chủ, thời điểm API và ảnh giao diện thống nhất múi giờ nghiệp vụ.

6.2. Kiến trúc và công nghệ

Hình 6.1. Kiến trúc tích hợp giao diện, backend và PostgreSQL.



Phương án triển khai dùng Node.js 24 LTS, Express và thư viện pg, kết nối PostgreSQL 17 với schema lab_tracker. Giao diện HTML, CSS và JavaScript được phục vụ cùng nguồn với API. Express phân tách middleware xác thực, kiểm tra đầu vào, service và repository. PostgreSQL giữ 16 bảng nền tảng cùng ba bổ sung grant_laboratory, chemical_certification và chemical_movement của Phase 3. PGlite là môi trường kiểm chứng SQL cục bộ; không thay cho PostgreSQL server khi thử nhiều kết nối.

Thành phần	Trách nhiệm	Hợp đồng đầu vào/đầu ra
Trình duyệt	Hiển thị biểu mẫu, danh sách, phản hồi lỗi và trạng thái tải	Gửi JSON qua /api/v1; nhận data hoặc error; không gửi SQL.
Middleware	Xác thực phiên, CSRF, phân quyền và kiểm tra định dạng	Tạo req.auth chứa account_id, person_id, quyền ứng dụng; từ chối trước khi gọi service nếu không hợp lệ.
Service	Thực hiện một nghiệp vụ nguyên tử	Lấy một kết nối pg cho toàn bộ BEGIN–COMMIT/ROLLBACK; truyền danh tính đã xác thực vào xử lý nghiệp vụ.
Repository	Gọi câu SQL hoặc routine được phép	Câu SQL cố định, tham số $1…$n, danh sách cột rõ ràng; chuẩn hóa lỗi CSDL thành mã ứng dụng.
PostgreSQL	Bảo vệ dữ liệu và giải quyết cạnh tranh	Kiểm tra điều kiện trên dữ liệu mới nhất dưới khóa; trả kết quả hoặc lỗi, không ghi dở dang.
Tác vụ định kỳ	Đồng bộ trạng thái chứng nhận, sao lưu	Tài khoản tác vụ riêng; chạy có nhật ký thời điểm, số dòng và kết quả; cho phép chạy lại an toàn.

Lựa chọn công nghệ dựa trên Node.js Releases (nodejs.org/en/about/previous-releases), tài liệu truy vấn và giao dịch của node-postgres (node-postgres.com/features/queries; node-postgres.com/features/transactions), cùng hướng dẫn bảo mật Express (expressjs.com/en/advanced/best-practice-security/). Mọi câu lệnh trong một giao dịch phải dùng cùng một client; giá trị đầu vào được truyền bằng mảng tham số thay vì ghép chuỗi SQL.

6.3. Danh tính và mô hình phân quyền

Faculty, Student và Technician là ba lớp con toàn phần, rời rạc của person; chúng mô tả tư cách học thuật và nghiệp vụ. Tài khoản đăng nhập và quyền ứng dụng là lớp bảo mật khác. Một Faculty không tự có quyền quản trị tất cả đề tài; quyền sửa đề tài phụ thuộc chủ nhiệm hoặc quyền quản trị được cấp. Tương tự, chỉ tài khoản gắn với Technician và có quyền vận hành mới tạo nhật ký bảo trì.

Lớp	Thiết kế tích hợp	Quy tắc xác minh
Danh tính nghiệp vụ	person_id liên kết đúng một lớp con theo Phase 2	Tài khoản bị khóa hoặc person.status khác Active không được tạo giao dịch mới.
Tài khoản ứng dụng	Bổ sung schema app_auth khi triển khai: user_account, account_role, session	user_account.person_id là FK UNIQUE; mật khẩu chỉ lưu bản băm; vai trò được cấp bởi quản trị, không nhận từ biểu mẫu đăng nhập.
Phiên đăng nhập	Cookie chỉ chứa mã phiên ngẫu nhiên; dữ liệu phiên ở máy chủ	Tái tạo mã phiên khi đăng nhập, hủy khi đăng xuất; hết hạn sau 30 phút không hoạt động và tối đa 8 giờ.
Quyền người dùng	member, research_admin, lab_operator, auditor	Quyền chức năng kết hợp kiểm tra chủ sở hữu bản ghi và lớp con; không dùng ẩn nút làm cơ chế phân quyền.
Quyền CSDL	lab_app; lab_technician kế thừa lab_app; lab_reader; lab_manager	lab_app gọi nghiệp vụ thông thường; lab_technician thêm nhập kho/bảo trì; lab_reader đọc; lab_manager quản lý danh mục/phân bổ. Mọi vai trò đều bị cấm sửa tồn và lịch sử trực tiếp.

Chủ thể	Tra cứu	Thao tác ghi	Phạm vi
Member	Tài sản, phòng, chứng nhận và lịch sử của bản thân	Tạo lượt mượn, trả thiết bị của mình, mở/đóng lượt ra vào đủ điều kiện	person_id lấy từ phiên; không cho thay người bằng request body.
Faculty phụ trách đề tài	Đề tài mình làm PI và báo cáo tài sản được cấp	Quản lý hạng mục, yêu cầu phân bổ, phê duyệt truy cập ngoài giờ	Không sửa ngân sách hoặc đề tài người khác nếu chưa được cấp research_admin.

Chủ thể	Tra cứu	Thao tác ghi	Phạm vi
Technician + lab_operator	Kho hóa chất, thiết bị, lịch sử vận hành	Nhập kho, bảo trì và phê duyệt truy cập; xuất hóa chất của bản thân theo chứng nhận	technician_id và người phê duyệt lấy từ phiên.
Research_admin	Danh mục, đề tài và phân bổ toàn hệ thống	Quản lý danh mục và phân quyền theo chính sách	Không được bỏ qua chứng nhận, khóa mượn hoặc ràng buộc tồn kho.
Auditor	View báo cáo đã giới hạn dữ liệu cá nhân	Không có thao tác ghi	Không xem bản băm mật khẩu, mã phiên hoặc thông tin nhạy cảm ngoài nhu cầu kiểm tra.

Ở API tự phục vụ, person_id lấy từ phiên và backend từ chối các trường person_id, technician_id, approved_by do trình duyệt tự gửi. POST /access-logs/approved là thao tác riêng dành cho phiên Faculty hoặc Technician: cán bộ chọn visitor_id, phòng và mục đích, sau đó trực tiếp phê duyệt và mở lượt truy cập. Backend gọi record_access với người được cán bộ xác minh và p_approver lấy từ phiên cán bộ. Sinh viên không có endpoint để tự khai báo đã được người khác duyệt. Quyền EXECUTE CSDL không tự chứng minh danh tính p_actor; kết nối backend là thành phần tin cậy chịu trách nhiệm ràng buộc danh tính này.

Backend dùng các pool tài khoản riêng cho đọc, nghiệp vụ thường, kỹ thuật viên và quản trị; ánh xạ pool được cố định trong mã theo quyền đã xác minh, không nhận tên role từ request. Các tài khoản LOGIN thực tế được DBA tạo và cấp vai trò nhóm tương ứng. Mỗi pool thiết lập rõ search_path và TimeZone; SET ROLE không tự áp dụng lại mặc định ALTER ROLE của role nhóm. Mọi repository dùng tên schema lab_tracker để tránh phụ thuộc tên đối tượng trong search_path.

Khi triển khai schema app_auth, migration tích hợp phải tạo các view đọc giới hạn gồm v_person_identity, v_borrow_history, v_access_history và v_maintenance_history. Chỉ đưa vào view những cột cần cho màn hình và xác thực, cấp SELECT theo role tương ứng, đồng thời buộc backend lọc theo danh tính hoặc phạm vi quản lý đã xác minh. lab_app hiện chỉ có quyền đọc danh mục và các view Phase 3; không dùng lab_manager thay tài khoản runtime để mở rộng quyền đọc lịch sử. Các truy vấn báo cáo Q01–Q12 có đọc trực tiếp bảng nhạy cảm nên chưa thể cấp nguyên bản cho lab_reader/lab_app. Migration tích hợp phải bổ sung view hoặc wrapper báo cáo có cột, phạm vi danh tính và GRANT giới hạn, rồi kiểm thử quyền từng báo cáo. Không đổi pool sang lab_manager để bỏ qua thiếu quyền.

6.4. Màn hình và luồng sử dụng

Màn hình	Dữ liệu và điều khiển	Hành vi sau thao tác
Đăng nhập	Email, mật khẩu, nút đăng nhập	Lỗi không tiết lộ tài khoản có tồn tại; đăng nhập thành công tới tổng quan theo quyền.
Tổng quan	Thiết bị khả dụng, lượt đang mượn, chứng nhận sắp hết hạn, hóa chất gần hết hạn	Các chỉ số dùng cùng mốc thời gian; nhấp chỉ số mở danh sách có bộ lọc tương ứng.
Đề tài và hạng mục	Chủ nhiệm, thời gian, ngân sách, trạng thái, phòng được cấp và hai danh sách phân bổ	Hiển thị rõ đề tài Completed/Suspended; từ chối ghi bằng backend và CSDL khi trạng thái không cho phép.
Thiết bị	Tìm tên/seri, lọc phòng/trạng thái, trang chi tiết, lịch sử mượn/bảo trì	Mượn cần chọn ngày trả dự kiến; sau thành công tải lại trạng thái thay vì giữ số liệu cũ.
Mượn trả của tôi	Danh sách chưa trả và lịch sử đã trả	Tách chưa trả bằng actual_return_date IS NULL; giao dịch trả trễ đã hoàn tất vẫn ở lịch sử.
Kho hóa chất	Tên, CAS, đơn vị, tồn, hạn dùng, mức nguy hiểm, điều kiện lưu trữ	Số lượng nhập dưới dạng thập phân; xuất thành công hiển thị số dư mới và mã chứng từ.
Ra vào phòng	Phòng, mục đích, lượt đang mở; biểu mẫu phê duyệt cho cán bộ	Giờ vào/ra do máy chủ xác lập; không cho đóng lượt của người khác khi thiếu quyền.
Chứng nhận và bảo trì	Ngày cấp/hết hạn; thiết bị, kỹ thuật viên, nội dung, chi phí bảo trì	Chứng nhận quá hạn hiện Expired theo thời gian thực; chỉ Technician mở hoặc kết thúc bảo trì.
Báo cáo	Danh sách truy vấn nâng cao và bộ lọc ngày, phòng, đề tài	Hiển thị cột rõ nghĩa, đơn vị đo và điều kiện lọc; xuất CSV chỉ theo quyền truy cập.

Mọi biểu mẫu giữ lại dữ liệu hợp lệ khi máy chủ trả lỗi và đặt thông báo cạnh trường liên quan. Khi gửi yêu cầu, nút xác nhận tạm khóa để giảm nhấp lặp; thành công chỉ hiển thị sau khi COMMIT. Không xóa lịch sử để làm mất dấu giao dịch. Với lỗi cạnh tranh, màn hình yêu cầu tải lại trạng thái trước khi người dùng thử lại.

6.5. Quy ước hợp đồng API

API dùng tiền tố /api/v1 và JSON UTF-8. Mã BIGINT biểu diễn bằng chuỗi chữ số trong JSON để tránh mất chính xác trong JavaScript; số tiền và lượng hóa chất cũng truyền bằng chuỗi thập phân, không tính số dư bằng số thực của trình duyệt. Ngày dùng YYYY-MM-DD; thời điểm phản hồi dùng ISO 8601 kèm +07:00. Các trường trạng thái giữ đúng miền giá trị ở Phase 2.

GET danh sách nhận page mặc định 1, page_size mặc định 20 và tối đa 100. sort chỉ nhận tên trong danh sách cho phép của endpoint; tên cột không được đưa trực tiếp từ người dùng vào SQL. Bộ lọc ngày dùng khoảng nửa mở từ from đến trước to khi lọc thời điểm. Với thao tác tự phục vụ, máy chủ xác lập thời điểm và danh tính; client chỉ gửi dữ liệu nghiệp vụ được phép.

Nhóm API	Đầu vào chính	Quyền và kiểm tra	Kết quả
POST /auth/login; POST /auth/logout; GET /auth/me	email/password; cookie phiên; CSRF khi đăng xuất	Giới hạn thử đăng nhập; xác minh bản băm, Active và phiên; logout hủy phiên máy chủ	200 người dùng/quyền; 204 đăng xuất; 401 khi chưa xác thực.
GET /labs; GET /equipment; GET /equipment/:id	q, lab_id, current_status, page, page_size	ID là chuỗi số dương; trạng thái trong miền; chỉ trả trường được phép	200 danh sách phân trang hoặc chi tiết; 404 khi không tồn tại.
GET /grants; GET /grants/:id	status, principal_investigator_id, khoảng ngày	Member xem trường cơ bản; ngân sách/chi tiết nội bộ theo phạm vi PI hoặc research_admin	200 đề tài, hạng mục và tài sản đã cấp; 403 nếu vượt phạm vi.
POST /grants/:id/points; POST /points/:id/equipment-allocations	Tên/miêu tả/ngày; equipment_id	PI của đề tài hoặc research_admin; thời gian phù hợp; đề tài Active và phòng tài sản được cấp	201 hạng mục hoặc liên kết; 409 nếu đã phân bổ/trạng thái thay đổi.
POST /points/:id/chemical-allocations	chemical_id	PI hoặc research_admin; kiểm tra đề tài Active và grant–lab; liên kết không phải phiếu xuất kho	201 liên kết; không giảm lượng tồn khi chỉ gắn hóa chất với hạng mục.
GET /me/borrows; POST /borrows	actual_return_date filter; equipment_id, expected_return_date	Người mượn lấy từ phiên; đang Active; không quá ba lượt chưa trả; thiết bị Available	200 lịch sử; 201 lượt mượn và trạng thái thiết bị mới; 409 xung đột.

Nhóm API	Đầu vào chính	Quyền và kiểm tra	Kết quả
POST /borrows/:id/return	Không nhận ngày trả hoặc trạng thái tự chọn	Chủ giao dịch lấy từ phiên; gọi return_equipment; máy chủ ghi ngày trả, không cho nhận trả thay người khác trong endpoint này	200 Returned/Overdue cùng actual_return_date; 409 nếu đã trả.
POST /access-logs; POST /access-logs/approved; POST /access-logs/:id/exit	lab_id, purpose; thêm visitor_id khi cán bộ phê duyệt	Tự phục vụ dùng danh tính phiên; phê duyệt yêu cầu Faculty/Technician; chứng nhận và giờ truy cập kiểm tra tại thời điểm hiện tại	201 lượt vào; 200 kết thúc; 403 thiếu điều kiện; 409 lượt đã đóng.
POST /chemical-issues; POST /chemical-receipts	Xuất: chemical_id, rearch_point_id, quantity, reason; nhập: chemical_id, quantity, reason	Xuất dùng người sử dụng từ phiên và kiểm tra mọi chứng nhận yêu cầu; nhập chỉ Technician + lab_operator; số lượng > 0, tối đa ba chữ số thập phân	201 movement_id; 409 thiếu tồn; 403 thiếu chứng nhận; không nhận recipient_id tự chọn
POST /maintenance; POST /maintenance/:id/complete	equipment_id, description, cost; ngày kết thúc do máy chủ xác lập	Technician + lab_operator; complete chỉ người đã mở nhật ký đó; không bảo trì thiết bị đang mượn; description không rỗng, cost không âm	201 nhật ký; 200 kết thúc bảo trì; 409 trạng thái không phù hợp.
GET /me/certifications; GET /reports/:code	Khoảng ngày, lab_id, grant_id; report code trong danh sách Q01–Q12	Người dùng chỉ xem chứng nhận mình; báo cáo theo quyền; không nhận chuỗi SQL	200 dữ liệu và điều kiện lọc; 400 bộ lọc sai; 403 không đủ quyền.

POST /chemical-issues gọi lab_tracker.issue_chemical: p_actor là người sử dụng hóa chất lấy từ phiên, p_point nhận rearch_point_id đã kiểm tra, không có recipient_id tùy chọn. Với High/Extreme, người đó phải có tất cả chứng nhận được cấu hình trong chemical_certification còn hiệu lực; thiếu chính sách chứng nhận cũng bị chặn. POST /chemical-receipts gọi receive_chemical và chỉ dành cho Technician đang Active. allocated_chem chỉ là liên kết hạng mục–hóa chất, không tự giảm tồn kho.

API / tác vụ	Đối tượng SQL Phase 3	Danh tính và quyền CSDL
Mượn / trả thiết bị	checkout_equipment(p_actor,p_equipment,p_due); return_equipment(p_actor,p_borrow)	p_actor = phiên người dùng; lab_app.
Vào / ra phòng	record_access(p_actor,p_lab,p_purpose,p_approver); close_access(p_actor,p_log)	Tự phục vụ: p_actor từ phiên, p_approver NULL. Staff phê duyệt: target do staff xác minh, approver từ phiên staff; lab_app.
Xuất / nhập hóa chất	issue_chemical(p_chemical,p_actor,p_point,p_quantity,p_reason); receive_chemical(p_chemical, p_actor,p_quantity,p_reason)	Xuất: actor từ phiên, lab_app. Nhập: Technician từ phiên, lab_technician.
Mở / kết thúc bảo trì	start_maintenance(p_actor,p_equipment,p_description,p_cost); finish_maintenance(p_actor,p_maintenance,p_description,p_cost)	Technician từ phiên; kết thúc nhật ký của chính Technician đó; lab_technician.
Trạng thái thời gian	refresh_temporal_status()	Tác vụ gọi dưới quyền được cấp từ lab_manager; không cung cấp endpoint công khai.
Tra cứu và báo cáo	Các view/danh mục đã được cấp SELECT trong Phase 3; Q01–Q12 qua view/wrapper báo cáo giới hạn cần bổ sung.	Tra cứu dùng lab_reader/lab_app theo GRANT hiện có. Báo cáo chỉ mở sau migration giới hạn quyền và kiểm thử phạm vi; backend lọc person_id/phạm vi từ phiên.

```
POST /api/v1/borrows
Content-Type: application/json
X-CSRF-Token: token từ phiên hiện tại

{"equipment_id":"1001","expected_return_date":"2026-11-05"}

201 Created
{"data":{"borrow_id":"501","equipment_id":"1001",
"status":"Borrowed","actual_return_date":null},
"request_id":"bpt-7f2c"}

409 Conflict
{"error":{"code":"BORROW_LIMIT_REACHED",
"message":"Bạn đang giữ đủ 3 thiết bị."},
"request_id":"bpt-7f2d"}
```

6.6. Kiểm tra đầu vào và ánh xạ lỗi

Đối tượng	Điều kiện kiểm tra	Cách xử lý
Chuỗi ký tự	Trim đầu/cuối; tên và mục đích không rỗng; giới hạn bằng VARCHAR tương ứng	Trả 400 VALIDATION_ERROR kèm tên trường; không cắt âm thầm làm thay đổi ý nghĩa.
ID/ngày/tiền/lượng	ID nguyên dương; ngày đúng lịch; DECIMAL đúng scale; lượng > 0, chi phí ≥ 0	Không nhận NaN, Infinity, chuỗi rỗng, dấu phân cách hàng nghìn hoặc lượng âm.
Lớp con và quan hệ	Tạo người và đúng một lớp con cùng giao dịch; PI thuộc Faculty; bảo trì bởi Technician	Giao diện chọn theo danh mục phù hợp; CSDL xác minh lại trước commit.
Trạng thái và thời gian	Miền trạng thái đúng chữ; đề tài/hạng mục: end_date > start_date; bảo trì: end_date >= start_date khi có; exit_time > entry_time; ngày trả không trước ngày mượn	Không cho người dùng tự đặt Borrowed/Returned/Overdue hoặc thời điểm giả để vượt điều kiện.
Phê duyệt	Người phê duyệt Active, thuộc Faculty/Technician, khác người cần phê duyệt	Backend xác lập approved_by từ phiên; yêu cầu phê duyệt không thay thế chứng nhận còn hiệu lực.
Tệp xuất và thông tin lỗi	Tên tệp do máy chủ sinh; báo cáo không lộ mật khẩu hay dữ liệu bị hạn chế	Mã lỗi ổn định; log nội bộ có request_id, endpoint, actor và SQLSTATE, không ghi bí mật.

HTTP / mã ứng dụng	Nguồn phát hiện	Phản hồi và tính nhất quán
400 VALIDATION_ERROR	Định dạng/miền giá trị; CHECK 23514 khi thích hợp	Chỉ ra trường sai; không để giao dịch đang mở.
401 UNAUTHENTICATED	Phiên thiếu, hết hạn hoặc bị thu hồi	Không thực hiện truy vấn nghiệp vụ ghi; đưa người dùng về đăng nhập.
403 FORBIDDEN / CERTIFICATION_REQUIRED	Không đủ quyền hoặc chứng nhận; logic an toàn nghiệp vụ	Không tiết lộ hồ sơ người khác; không ghi nhật ký truy cập thành công cho yêu cầu bị chặn.
404 NOT_FOUND	Đối tượng không tồn tại hoặc không được phép xác nhận tồn tại	Một cấu trúc lỗi thống nhất; không trả kết quả thành công rỗng cho thao tác ghi.
409 ALREADY_EXISTS / INVALID_STATE	UNIQUE 23505; FK 23503; thiết bị đang bận; phân bổ trùng	Rollback; tải lại dữ liệu liên quan; giữ nguyên lịch sử.

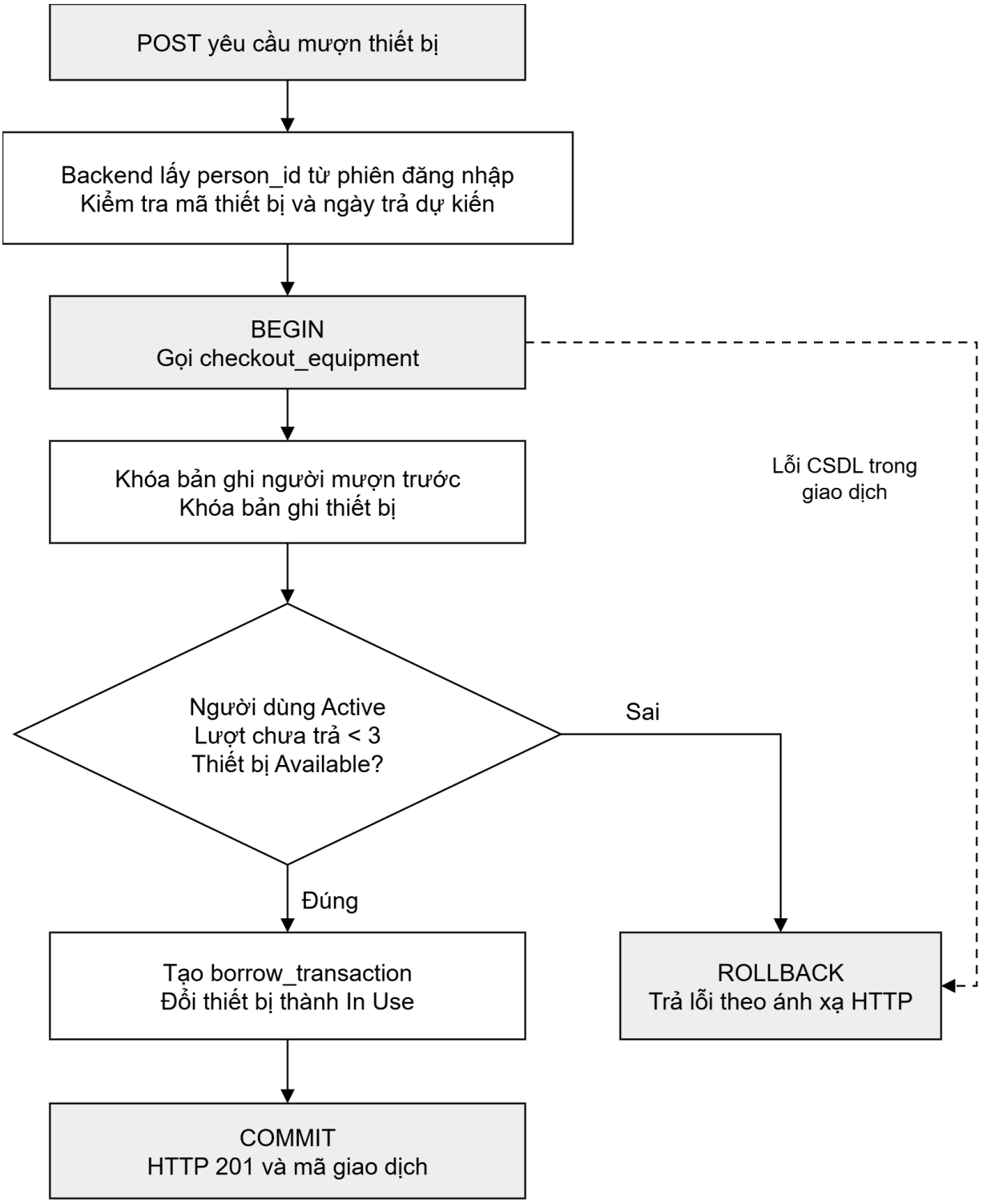
HTTP / mã ứng dụng	Nguồn phát hiện	Phản hồi và tính nhất quán
409 BORROW_LIMIT_REACHED / INSUFFICIENT_STOCK	Trigger/routine phát hiện giới hạn dưới khóa	Không tăng số lượt, không giảm tồn và không tạo chứng từ dở dang.
409 RETRY_CONFLICT	40001 hoặc 40P01 sau số lần thử lại giới hạn	Backend thử lại toàn bộ giao dịch tối đa hai lần nếu an toàn; không thử lại riêng câu lệnh giữa giao dịch.
503 DATABASE_UNAVAILABLE	Mất kết nối hoặc lock timeout 55P03	Thông báo tạm thời không xử lý được; tra trạng thái giao dịch trước khi gửi lại thao tác có thể đã commit.
500 INTERNAL_ERROR	Lỗi ngoài các trường hợp đã ánh xạ	Trả thông điệp chung và request_id; không đưa câu SQL, stack trace hay mật khẩu vào phản hồi.

Mã nghiệp vụ là hợp đồng HTTP dự kiến của backend. SQLSTATE chỉ được ánh xạ cụ thể khi biết tên constraint hoặc routine đã phát sinh lỗi; không đổi mọi lỗi P0001 thành cùng một nguyên nhân. Với yêu cầu ghi bị ngắt kết nối sau commit, giao diện tra cứu lại lịch sử bằng mã giao dịch hoặc yêu cầu người dùng xác nhận trạng thái, tránh tự động nhân đôi giao dịch.

6.7. Giao dịch và cạnh tranh

Service gọi checkout_equipment hoặc return_equipment của Phase 3 trong cùng client và giao dịch; các điều kiện, thứ tự khóa và tính nguyên tử được xác định tại Phase 3, mục 4.1.2–4.1.3 và ma trận BR01–BR26 ở mục 5.1.1. Backend gắn danh tính từ phiên, kiểm tra phạm vi bản ghi, chỉ trả thành công sau COMMIT và ánh xạ lỗi qua hợp đồng HTTP mục 6.6.

Hình 6.2. Luồng mượn thiết bị từ danh tính đã xác thực đến commit.



Service dùng lại routine Phase 3, không tạo đường ghi trực tiếp bỏ qua kiểm tra. Giao dịch ngắn, không chờ người dùng hoặc gọi mạng bên ngoài khi đang giữ khóa. Hết thời gian chờ phải rollback, giải phóng kết nối và trả lỗi có thể xử lý. Không dùng khóa trong tiến trình backend để thay cơ chế bảo vệ CSDL.

```
async function inTransaction(pool, operation) {
  const client = await pool.connect();
  try {
    await client.query('BEGIN');
    const result = await operation(client);
    await client.query('COMMIT');
    return result;
  } catch (error) {
    await client.query('ROLLBACK');
    throw error;
  } finally {
    client.release();
  }
}
```

Đoạn mã trên là mẫu tích hợp cho service, chưa tạo thành ứng dụng web. Lệnh nghiệp vụ được truyền vào operation phải dùng chính client được cấp; không gọi pool.query xen giữa giao dịch. Nếu lỗi kết nối khiến rollback thất bại, lớp kết nối loại bỏ client hỏng và ghi nguyên nhân gốc để xử lý vận hành.

6.8. Truy vấn tham số hóa và ngày hết hạn

```
const result = await pool.query(
  `SELECT equipment_id, equipment_name, current_status
   FROM lab_tracker.equipment
   WHERE lab_id = $1::bigint
     AND current_status = $2
   ORDER BY equipment_id
   LIMIT $3::integer OFFSET $4::integer`,
  [labId, 'Available', pageSize, offset]
);
return result.rows;
```

Ví dụ chỉ đọc các cột cần hiển thị và dùng chỉ số phân trang đã được kiểm tra. Tên schema được cố định tại cấu hình repository theo gói SQL Phase 3, không lấy từ query string. Ký tự dấu nháy trong bộ lọc phải được coi là dữ liệu; tuyệt đối không nối q, id, sort hoặc tên báo cáo vào một câu SQL tùy ý.

Tác vụ thời gian được thiết kế chạy lúc 00:05 hằng ngày theo Asia/Ho_Chi_Minh bằng bộ lập lịch hệ điều hành, dưới tài khoản được cấp EXECUTE refresh_temporal_status của Phase 3. Tích hợp cần ghi kết quả, chạy bù khi khởi động lại và xác nhận tính lặp lại an toàn. Cơ chế xử lý trạng thái/chứng nhận theo ngày đã mô tả ở Phase 3, mục 4.1.2; lịch chạy này chưa được triển khai.

```
SELECT lab_tracker.refresh_temporal_status();
```

Nhật ký tác vụ lưu thời điểm, số chứng nhận được chuyển trạng thái và lỗi. Giao diện hiển thị ngày theo múi giờ nghiệp vụ và diễn giải các mốc truy cập theo Phase 2, mục 2.2.9; backend truyền thời điểm do máy chủ xác lập vào routine Phase 3. Khi nghiệm thu cần kiểm tra biên 17:00 của Student và ngày hết hạn bằng hôm nay, cả trước lẫn sau khi tác vụ chạy; không chỉ kiểm tra nhãn trạng thái trên màn hình. SQL hiện yêu cầu purpose không rỗng cho mọi lượt Faculty; không có nhánh kiểm tra riêng theo khung 06:00–22:00. Nghiệm thu cần xác nhận cách thu lý do đáp ứng chính sách Faculty của Phase 1/2 trước khi công bố đã hoàn thiện quy tắc này.

7. Kiểm thử và nghiệm thu tích hợp

7.1. Phân biệt bằng chứng đã có và kiểm thử tiếp theo

Bằng chứng lớp dữ liệu được tham chiếu ở Phase 3: mục 4.1 có DDL/DML; mục 4.2 có 12 truy vấn và kết quả; mục 4.3.1 có phép đo seed thực tế; mục 5 có 44/44 kiểm thử nghiệp vụ và 10/10 kiểm thử quyền. Phase 4 chưa có trình duyệt, Express server, phiên đăng nhập hoặc kết nối mạng thực tế. Toàn bộ ca HTTP, hai kết nối PostgreSQL máy chủ, phục hồi, trình diễn trực tiếp và đánh giá đồng đội vẫn chưa được thực hiện.

Lớp kiểm chứng	Bằng chứng sử dụng	Trạng thái tại bàn giao
Mô hình và ràng buộc	Lược đồ Phase 2, DDL và ca kiểm thử SQL Phase 3	Thiết kế và kết quả SQL theo báo cáo Phase 3; không tự suy ra kết quả web.
Truy vấn và hiệu năng SQL	Kết quả và 180 lần đo trực tiếp + 180 EXPLAIN ANALYZE tại Phase 3, mục 4.3.1	Đã đo trên seed nhỏ của PGlite một phiên; chưa xác nhận SQL ở quy mô vận hành, HTTP, giao diện hoặc NFR02 của Phase 1.
API và xác thực	Request/response thực tế, test tự động và log ứng dụng	Chưa triển khai; cần thực hiện theo hợp đồng mục 6.5.
Hai phiên PostgreSQL native	Hai kết nối độc lập, thứ tự khóa và kết quả commit/rollback	Cần thực hiện trước nghiệm thu web; PGlite đơn kết nối không xác nhận được ca này.
Giao diện, trình diễn và đánh giá	Video/ảnh phiên chạy, trình bày trực tiếp, phiếu cá nhân	Thực hiện sau khi ứng dụng kết nối CSDL; không có điểm hoặc đóng góp cá nhân được tự tạo.

7.2. Ma trận truy vết

Yêu cầu	Quy tắc Phase 1/2	Đối tượng dữ liệu	Ca nghiệm thu
FR01	PI là Faculty; ngân sách không âm; đề tài ngừng không nhận phân bổ	research_grant, research_point và các bảng phân bổ/phòng cấp	AT05, AT09
FR02–FR03	Cấm mượn Under Maintenance/Retired; tối đa ba chưa trả; trả trễ Overdue	equipment, borrow_transaction	AT01, AT02, AT03, AT10
FR04	Giờ truy cập và phê duyệt; chứng nhận hợp lệ; exit sau entry	person/lớp con, has_certification, access_log	AT04, AT06
FR05	Tồn không âm; hóa chất quá hạn không được xuất; High/Extreme cần chứng nhận; Extreme ở Hazardous	chemical, chứng nhận yêu cầu, chứng từ kho	AT07, AT08, AT11
FR06	Chứng nhận hết hạn chuyển Expired; Technician thực hiện bảo trì	has_certification, technician, maintenance_log	AT06, AT10
FR07–FR08	Bảo toàn lịch sử; FK hợp lệ; phân quyền và truy vấn an toàn	Nhật ký, view/routine và tài khoản CSDL	AT12, AT13, AT14

7.3. Các tình huống nghiệm thu web

Mã	Dữ liệu và thao tác	Kết quả bắt buộc
AT01	Đăng nhập người Active chưa mượn thiết bị; mượn một thiết bị Available với ngày trả hợp lệ	201; một borrow mới có actual_return_date NULL; thiết bị In Use; lịch sử giao diện khớp SELECT CSDL.
AT02	Người đang giữ ba thiết bị gửi yêu cầu thứ tư, kể cả đang có một lượt chưa trả đã quá hạn	409 BORROW_LIMIT_REACHED; số lượt chưa trả vẫn bằng ba; thiết bị thứ tư không đổi.
AT03	Hai người gửi yêu cầu mượn cùng một thiết bị gần đồng thời	Chỉ một giao dịch commit; giao dịch còn lại nhận xung đột; không có hai lượt mở cho cùng thiết bị.

Mã	Dữ liệu và thao tác	Kết quả bắt buộc
AT04	Student vào lúc ngoài [07:00, 17:00) chưa được phê duyệt; sau đó Faculty hợp lệ phê duyệt	Lần đầu 403; lần sau chỉ thành công khi đồng thời thỏa chứng nhận và điều kiện phòng; approved_by đúng phiên cán bộ.
AT05	PI hoặc research_admin gắn thiết bị vào research_point của đề tài Suspended hoặc từ phòng chưa cấp	Bị từ chối; không thêm allocated_equip; tài sản và ngân sách giữ nguyên.
AT06	Chứng nhận expiry_date là hôm qua nhưng status còn Valid; tác vụ hết hạn chưa chạy	Truy cập Restricted/Hazardous vẫn bị chặn; chạy tác vụ hai lần cho cùng kết quả cuối.
AT07	Người dùng thiếu một chứng nhận bắt buộc thử xuất hóa chất High; sau đó thử bằng tài khoản đủ mọi chứng nhận	Lần đầu 403 và không đổi tồn; lần sau tạo chemical_movement đúng người từ phiên, hạng mục, lượng và số dư.
AT08	Xuất số lượng lớn hơn tồn, hoặc xuất hóa chất đã quá hạn	Từ chối; cả tồn và lịch sử xuất đều giữ nguyên; thông báo phân biệt thiếu tồn và quá hạn.
AT09	Quản trị đặt remaining_budget âm hoặc lớn hơn total_budget; phân bổ đồng thời lúc đề tài chuyển Completed	CHECK chặn số dư sai; không có phân bổ mới được commit sau khi trạng thái đóng có hiệu lực dưới khóa.
AT10	Mượn thiết bị Under Maintenance; người Student thử tạo nhật ký bảo trì	Mượn bị chặn; endpoint bảo trì trả 403 và FK/logic nghiệp vụ vẫn bảo vệ lớp Technician.
AT11	Đổi phòng chứa hóa chất Extreme sang phòng Normal hoặc hạ mức an toàn phòng đang chứa Extreme	Cả hai hướng cập nhật đều bị chặn; không tạo trạng thái lưu trữ không an toàn.
AT12	Đổi person_id/approved_by trong body, truy cập lịch sử người khác và gửi bộ lọc chứa dấu nháy	Không giả mạo danh tính; không lộ hồ sơ ngoài quyền; bộ lọc được coi là dữ liệu và cấu trúc SQL không đổi.
AT13	Cookie hết hạn, thiếu CSRF hoặc auditor gửi POST ghi; runtime thử UPDATE tồn trực tiếp	401/403 hoặc lỗi quyền CSDL tương ứng; không dữ liệu nghiệp vụ nào bị sửa.
AT14	Mô phỏng lỗi sau thay đổi đầu tiên nhưng trước commit; phục hồi một bản sao lưu sang CSDL mới	Nghiệp vụ rollback hoàn toàn; phục hồi giữ đúng số dòng, PK/FK, trạng thái và truy vấn nghiệp vụ.

7.4. Kiểm thử đồng thời trên PostgreSQL server

CC01 và CC02 tái sử dụng T14 và H13 trong 06_concurrency.mjs và thiết kế khóa ở Phase 3, mục 4.1.3: cạnh tranh giới hạn ba lượt mượn và xuất vượt tổng lượng tồn. Hai ca vẫn chưa chạy trên PostgreSQL máy chủ. Khi triển khai web, thêm hai yêu cầu HTTP độc lập, xác minh yêu cầu sau chờ khóa nhận lỗi đúng, rồi đối chiếu số lượt/tồn/chứng từ với CSDL; chỉ chạy trên database thử riêng.

CC03 bổ sung tình huống hai người mượn cùng thiết bị; CC04 bổ sung đóng đề tài đồng thời phân bổ. Hai ca bổ sung phải được hiện thực ở bộ kiểm thử tích hợp khi triển khai. Khi gặp deadlock hoặc serialization failure, thử lại toàn bộ nghiệp vụ có giới hạn và xác minh không nhân đôi chứng từ.

7.5. Hiệu năng và an toàn vận hành

Bộ đo tích hợp dùng quy mô thiết bị/giao dịch và mục tiêu NFR02 tại Phase 1, mục 1.4, tách khỏi seed minh họa. Bổ sung nhật ký truy cập đại diện cho tải dự kiến. Với mỗi truy vấn trọng tâm, chạy khởi động, đo 30 lần, báo cáo trung vị, p95, số dòng và EXPLAIN (ANALYZE, BUFFERS). Đo riêng SQL, độ trễ HTTP và thời gian hiển thị; chỉ nghiệm thu mục tiêu sau phép đo phù hợp.

Kế hoạch truy vấn và kết quả EXPLAIN của SQL giữ tại Phase 3, mục 4.3; Phase 4 bổ sung request_id để nối thời gian chờ pool, truy vấn, HTTP và thời gian hiển thị của cùng yêu cầu. Báo cáo riêng độ trễ từng lớp, số người dùng đồng thời và môi trường. So sánh kết quả trước/sau tối ưu để không đổi ý nghĩa nghiệp vụ. Phép đo HTTP/trình duyệt và bộ dữ liệu quy mô nêu trên chưa được chạy.

8. Kịch bản trình diễn và bảo vệ

8.1. Kịch bản nhóm trong 12 phút

Thời gian	Vai trò trình bày	Nội dung và bằng chứng
00:00–01:00	A	Nêu bài toán quản lý tài sản và rủi ro an toàn; chỉ ra phạm vi theo dõi đề tài, thiết bị, hóa chất và ra vào.
01:00–03:00	A	Trình bày PERSON toàn phần/rời rạc, 16 bảng nền tảng Phase 2, research_point và những bổ sung vật lý Phase 3; giải thích PK/FK và một phân rã không mất mát.

Thời gian	Vai trò trình bày	Nội dung và bằng chứng
03:00–05:00	B	Trên phiên chạy thật sau triển khai: đăng nhập, tìm thiết bị, mượn thành công; thử vượt ba thiết bị và xác nhận DB giữ nguyên.
05:00–07:00	B	Thử vào phòng nguy hiểm thiếu chứng nhận và xuất hóa chất quá hạn; hiển thị lỗi ứng dụng cùng truy vấn kiểm tra không có thay đổi sai.
07:00–09:00	C	Chạy hai truy vấn nâng cao: JOIN/GROUP BY/HAVING và NOT EXISTS hoặc CTE; giải thích một view và một trigger.
09:00–10:30	C	Trình bày ca hai phiên, chỉ mục/kế hoạch thực thi và giới hạn số đo; thử quyền đọc/ghi bằng vai trò phù hợp.
10:30–12:00	A, B, C	Mỗi người giải thích một câu SQL hoặc tình huống cập nhật tại chỗ; kết luận mức hoàn thành bằng bằng chứng thực tế và phân chia trả lời câu hỏi.

Trước buổi bảo vệ, chuẩn bị bản sao dữ liệu riêng, tài khoản theo từng quyền và danh sách truy vấn kiểm tra kết quả. Không dùng tài khoản owner để minh họa người dùng thường. Kịch bản được thực hiện sau khi có website; các thao tác trong bảng là kế hoạch trình diễn, chưa phải bản ghi một buổi demo đã diễn ra.

8.2. Bảo vệ SQL cá nhân

Vai trò	Câu hỏi thực hành	Tiêu chí trả lời đạt
A: mô hình và tính toàn vẹn	Vì sao FK ba lớp con chưa bảo đảm mỗi PERSON thuộc đúng một lớp? Tạo người thiếu lớp con và giải thích thời điểm từ chối.	Nêu total/disjoint, giao dịch tạo người và kiểm tra tại commit; chỉ ra PK/FK khác ràng buộc nhiều bảng.
A: chuẩn hóa	Chứng minh tách laboratory khỏi equipment không mất mát; phân biệt khóa ứng viên với mã định danh được tự đặt.	Nêu lab_id là khóa của phần giao và FD tương ứng; không khẳng định có surrogate key thì tự đạt BCNF.

Vai trò	Câu hỏi thực hành	Tiêu chí trả lời đạt
B: nghiệp vụ và giao dịch	Viết truy vấn đếm thiết bị đang giữ; giải thích vì sao không chỉ lọc status = Borrowed.	Dùng actual_return_date IS NULL; nhận ra lượt Overdue chưa trả vẫn tính, còn trả trễ đã hoàn tất không tính.
B: an toàn hóa chất	Giải thích các bước xuất hóa chất High khi hai người xuất đồng thời.	Kiểm tra đúng chứng nhận và ngày, khóa tồn, kiểm tra lượng, tạo chứng từ và giảm tồn nguyên tử.
C: truy vấn và hiệu năng	Viết báo cáo phòng không có thiết bị đang mượn bằng NOT EXISTS; so sánh với LEFT JOIN.	Điều kiện tương quan đúng, xử lý NULL và thiết bị chưa có lịch sử; không tạo trùng hoặc bỏ phòng rỗng.
C: bảo mật	Chứng minh auditor không sửa được dữ liệu; giải thích tham số $1 và quyền của runtime.	Thực hiện bằng tài khoản giới hạn; phân biệt tham số dữ liệu với tên đối tượng; không dựa vào ẩn nút giao diện.

A, B và C là ba vị trí trình bày để các thành viên thật tự phân công. Mỗi vị trí đều phải hiểu mô hình, ít nhất hai truy vấn nâng cao và một giao dịch quan trọng. Khi giảng viên đổi dữ liệu đầu vào hoặc điều kiện truy vấn, người trả lời cần dự đoán kết quả trước khi chạy và giải thích thay đổi bằng dữ liệu thực tế.

8.3. Đánh giá đồng đội

Theo kế hoạch môn học, đánh giá đồng đội chiếm 15% điểm dự án cá nhân và phần bảo vệ SQL cá nhân chiếm 15%. Phiếu sau được từng thành viên hoàn thành sau khi cùng triển khai và bảo vệ. Điểm, bằng chứng và nhận xét do người đánh giá thật ghi; báo cáo này không xác nhận đóng góp hay tự phân bổ điểm cho bất kỳ ai.

Tiêu chí	Trọng số	Bằng chứng được xem xét
Đóng góp sản phẩm	30%	Phần mô hình, SQL, dữ liệu, giao diện hoặc kiểm thử được bàn giao, chạy được và được nhóm rà soát.
Chất lượng kỹ thuật	25%	Tính đúng đắn, khả năng giải thích, xử lý lỗi và tuân thủ ràng buộc nghiệp vụ.
Hợp tác và tiến độ	20%	Thực hiện cam kết, phối hợp, hỗ trợ thành viên và cập nhật tiến độ hằng tuần.

Tiêu chí	Trọng số	Bằng chứng được xem xét
Hiểu toàn bộ hệ thống	15%	Giải thích được liên kết giữa mô hình, SQL, backend và kết quả kiểm thử.
Trình bày và phản biện	10%	Demo rõ ràng, trả lời truy vấn tại chỗ, lập luận dựa trên bằng chứng.

Mỗi tiêu chí chấm từ 1 đến 5: 1 là không có đóng góp kiểm chứng được; 2 là đóng góp thiếu hoặc cần hỗ trợ nhiều; 3 là đáp ứng nhiệm vụ; 4 là hoàn thành tốt và chủ động hỗ trợ; 5 là hoàn thành xuất sắc, có bằng chứng rõ và giúp nhóm giải quyết vấn đề khó. Điểm tổng trên thang 100 bằng tổng của (điểm tiêu chí / 5 × trọng số).

Phiếu đánh giá cá nhân	Thông tin điền sau thực hiện
Họ tên người đánh giá	
Họ tên người được đánh giá	
Ngày đánh giá	
Đóng góp sản phẩm: điểm 1–5 và bằng chứng	
Chất lượng kỹ thuật: điểm 1–5 và bằng chứng	
Hợp tác và tiến độ: điểm 1–5 và bằng chứng	
Hiểu toàn bộ hệ thống: điểm 1–5 và bằng chứng	
Trình bày và phản biện: điểm 1–5 và bằng chứng	
Điểm tổng / 100	
Nội dung cần cải thiện	
Xác nhận người đánh giá	

9. Kế hoạch triển khai và bàn giao

9.1. Cấu trúc mã nguồn khi thực thi

Khi bắt đầu xây dựng website, tạo một thư mục ứng dụng riêng và giữ nguyên gói SQL Phase 3 làm mốc. Cấu trúc dưới đây là cấu trúc sẽ tạo ở bước triển khai; chưa có ứng dụng được sinh hoặc chạy trong giai đoạn soạn báo cáo.

```
university-lab-tracker/
  package.json
  package-lock.json
  .env.example
  sql/
  src/
    app.js
    server.js
    config/database.js
    middleware/auth.js
    middleware/permissions.js
    middleware/validate.js
    middleware/error-handler.js
    routes/
    services/
    repositories/
    jobs/expire-certifications.js
  public/
    index.html
    css/app.css
    js/api.js
    js/pages/
  tests/
    api/
    integration/
  artifacts/test-results/
  backups/
```

Cấu hình	Giá trị/quy ước	Mục đích
NODE_ENV; PORT	development; 3000 cho máy cá nhân	Tách hành vi hiển thị lỗi và chế độ cookie khi chạy HTTPS.
PGHOST; PGPORT; PGDATABASE	127.0.0.1; 5432; bpt_lab_tracker	Kết nối PostgreSQL server dành riêng cho đồ án.
PGUSER; PGPASSWORD	Tài khoản runtime và mật khẩu nhập tại môi trường triển khai	Không dùng owner/superuser; không ghi mật khẩu thật vào mã nguồn, ảnh hoặc báo cáo.
SESSION_SECRET	Sinh bằng bộ tạo số ngẫu nhiên mật mã khi cài đặt	Ký/kiểm chứng phiên; không có giá trị mặc định dùng chung.
APP_TIME_ZONE	Asia/Ho_Chi_Minh	Đồng bộ hiển thị, nghiệp vụ ngày và tác vụ định kỳ.
DATABASE_POOL_MAX	10 kết nối cho môi trường đồ án	Giới hạn tải; theo dõi thời gian chờ và giải phóng client ở finally.
Cấu hình session/CSRF	Cookie HttpOnly, SameSite=Lax; Secure trên HTTPS; phiên lưu máy chủ	Bảo vệ đăng nhập và yêu cầu ghi; không dùng bộ nhớ tiến trình làm nơi lưu phiên sản xuất.

9.2. Trình tự chuyển sang PostgreSQL và khởi động

Bước	Thực hiện	Điều kiện chuyển bước
1	Tạo CSDL UTF-8 riêng; thiết lập múi giờ; tạo tài khoản migration và runtime theo RBAC Phase 3	Kết nối migration được; runtime không có quyền owner/superuser.
2	Chạy 01_schema.sql, 02_seed.sql, 04_rbac.sql; dùng 03_queries.sql đối chiếu truy vấn và 05_tests.sql kiểm tra toàn vẹn	Không bỏ qua lỗi; xác nhận đủ bảng, routine, trigger và view; không nạp seed vào dữ liệu thật.
3	Chạy run_validation.mjs ở môi trường nhúng; sau đó chạy 06_concurrency.mjs trên PostgreSQL server dùng riêng	Ghi log kết quả T14/H13; bổ sung CC03–CC04 trước nghiệm thu web; không dùng kết quả PGlite để tuyên bố nhiều kết nối đã đạt.
4	Tạo migration app_auth cho tài khoản, quyền và phiên; gắn mỗi tài khoản với person có đúng lớp con	Không sửa khóa rearch_point_id hoặc tự đổi lược đồ nghiệp vụ; tài khoản và bản băm được tạo qua công cụ quản trị.
5	Tạo backend theo API; tạo giao diện; kiểm thử HTTP và trình duyệt	AT01–AT14 đạt; không có đường ghi tồn hoặc ngân sách bỏ qua nghiệp vụ.
6	Lập lịch hết hạn/sao lưu, thử phục hồi; đóng gói cấu hình và hướng dẫn chạy	Khởi động từ máy sạch theo hướng dẫn; kiểm tra quyền, thời gian và demo 12 phút.

```
node --version
npm --version
psql --version
createdb --encoding=UTF8 bpt_lab_tracker
psql -d bpt_lab_tracker -v ON_ERROR_STOP=1 -f sql/01_schema.sql
psql -d bpt_lab_tracker -v ON_ERROR_STOP=1 -f sql/02_seed.sql
psql -d bpt_lab_tracker -v ON_ERROR_STOP=1 -f sql/04_rbac.sql
psql -d bpt_lab_tracker -v ON_ERROR_STOP=1 -f sql/03_queries.sql
psql -d bpt_lab_tracker -v ON_ERROR_STOP=1 -f sql/05_tests.sql

npm ci
npm run db:verify
npm test
npm run dev
```

Lệnh npm chỉ áp dụng sau khi mã nguồn và package-lock.json đã được tạo. db:verify chạy kiểm tra SQL Phase 3; test chạy API/tích hợp; dev khởi động Express. Gói đi kèm gồm 01_schema.sql, 02_seed.sql, 03_queries.sql, 04_rbac.sql, 05_tests.sql, run_validation.mjs và 06_concurrency.mjs. run_validation.mjs kiểm chứng bằng PGlite; 06_concurrency.mjs cần thư viện pg và DATABASE_URL trỏ tới PostgreSQL server có seed mới. Khi có dữ liệu thực, chỉ áp dụng migration tăng dần đã rà soát và sao lưu trước.

9.3. Sao lưu, phục hồi và nhật ký

Lịch sao lưu và mục tiêu phục hồi lấy từ NFR04 tại Phase 1, mục 1.4. Triển khai dùng pg_dump định dạng custom; phục hồi vào database mới để kiểm tra trước khi thay thế hệ thống đang dùng. Bản sao nghiệp vụ và cấu hình tài khoản quản lý riêng; tệp chứa bí mật nằm trong vùng được bảo vệ. Đối chiếu số dòng, FK, lượt mượn mở, tồn hóa chất, ngân sách và các truy vấn báo cáo, đồng thời ghi thời điểm bản sao và thời lượng phục hồi thực tế.

```
pg_dump -h 127.0.0.1 -U bpt_backup -Fc -d bpt_lab_tracker -f
backups/bpt_lab_tracker.dump
createdb --encoding=UTF8 bpt_lab_tracker_restore
pg_restore -h 127.0.0.1 -U bpt_migrator --no-owner --exit-on-error -d
bpt_lab_tracker_restore backups/bpt_lab_tracker.dump
```

bpt_backup và bpt_migrator là tài khoản vận hành sẽ được DBA tạo; gói Phase 3 mới định nghĩa các vai trò nhóm NOLOGIN, không tạo mật khẩu đăng nhập. Mỗi tệp sao lưu thực tế dùng hậu tố ngày giờ để giữ lịch sử. Sau phục hồi, áp dụng lại RBAC và xác nhận runtime vẫn bị giới hạn. pg_dump custom và pg_restore được dùng theo tài liệu PostgreSQL 17: postgresql.org/docs/17/app-pgdump.html.

Nhật ký ứng dụng gồm request_id, thời điểm, endpoint, mã kết quả, actor đã xác thực, mã đối tượng và thời gian xử lý; không lưu password, cookie phiên hay toàn bộ chuỗi kết nối. Lỗi CSDL có SQLSTATE và tên constraint/routine ở log nội bộ. Sao lưu thất bại, tác vụ hết hạn lỗi hoặc tỷ lệ lỗi tăng phải được ghi nhận để người vận hành xử lý.

9.4. Điều kiện sẵn sàng triển khai

Hạng mục bàn giao	Điều kiện sẵn sàng	Bằng chứng cần có sau triển khai
Tài liệu và cơ sở dữ liệu	Phase 1–2 làm nền; Phase 3 có script, seed, truy vấn và kết quả kiểm chứng; Phase 4 có hợp đồng tích hợp	Gói mã nguồn giữ đúng mô hình và chạy lại SQL thành công.

Hạng mục bàn giao	Điều kiện sẵn sàng	Bằng chứng cần có sau triển khai
An toàn nghiệp vụ	Quy tắc truy cập, chứng nhận, mượn, kho và phân bổ đã có cơ chế dữ liệu cụ thể	AT01–AT14 và CC01–CC04 đạt trên PostgreSQL native.
Giao diện và API	Màn hình, endpoint, quyền, validation và lỗi được xác định trong tài liệu	Trình duyệt kết nối backend và CSDL thật; kiểm tra cả đường thành công và bị chặn.
Vận hành	Đã xác định cấu hình, triển khai, tác vụ định kỳ, sao lưu và phục hồi	Khởi động máy sạch, tác vụ chạy lại an toàn, phục hồi thử thành công.
Bảo vệ nhóm	Kịch bản 12 phút, câu hỏi A/B/C và phiếu đánh giá đã chuẩn bị	Các thành viên thực hiện demo, trả lời SQL và điền đánh giá bằng đóng góp thực tế.

Hồ sơ này sẵn sàng để bắt đầu thực thi website theo phương án đã chốt. Điều kiện hoàn thành phần tích hợp của Phase 4 chỉ được xác nhận sau khi ứng dụng chạy với PostgreSQL server, vượt các ca nghiệm thu và được trình diễn trực tiếp. Kết quả bảo vệ và đánh giá đồng đội được bổ sung từ buổi thực hiện thật.

9.5. Lệnh tiếp tục triển khai

Triển khai website University Research & Lab Asset Tracker theo BPT-Phase3 và BPT-Phase4 đã bàn giao. Dùng Node.js 24 LTS, Express, pg và PostgreSQL server; giữ mô hình Phase 2 cùng các bổ sung Phase 3, bao gồm rearch_point_id. Tạo backend, giao diện tiếng Việt, tài khoản/phiên, RBAC, nghiệp vụ an toàn và các API mục 6.5; dùng gói SQL đi kèm làm nguồn chuẩn. Chạy kiểm thử SQL, AT01–AT14 và hai phiên CC01–CC04, thử sao lưu/phục hồi, hoàn thiện hướng dẫn cài đặt rồi mở bản chạy cục bộ để kiểm tra.